

Copilot Mapped to the NIST AI RMF

1. *Scope*

Employees at a company use Copilot to draft customer communications. This register maps that use to the four functions of the AI Risk Management Framework (Govern, Map, Measure, Manage), documenting the risks and the controls that reduce them.

2. *The four functions*

- Govern: Who's in charge? What are the rules and policies?
- Map: What does this AI do? Who uses it? What could go wrong?
- Measure: How do you test and track whether it is working safely and fairly?
- Manage: what do you do about the risks you found?

3. *Risk and control*

	Function	Risk	Control
1	Govern	Employees utilize Copilot however they wish.	1. Write an acceptable use policy stating approved tasks and prohibited ones. 2. Require employees to read and acknowledge the policy through training.
2	Govern	Employees may use unapproved third-party AI applications to process customer or company information, potentially bypassing organizational security, privacy, and governance controls.	1. Publish a list of approved AI tools and require approval for new ones. 2. Monitor or block unapproved AI sites through IT and make approved tools easy to use in order to allow employees to feel confident in utilizing it.
3	Map	Employees may enter sensitive customer details (customer	1. Define which data types are off limits for prompts.

		name, addresses, financial data, contracts), into Copilot, potentially resulting in unauthorized disclosure or inappropriate use of customer information.	2. Use technical safeguards such as DLP and sensitivity labels.
4	Measure	Copilot may generate inaccurate, incomplete, or outdated information that appears credible, resulting in customer communications containing incorrect information.	1. Require human review before anything goes to a customer. 2. Have monthly check ups with a sample of AI outputs and track for error rates.
5	Manage	AI- generated communications may contain discriminatory, defamatory, misleading, or inappropriate content, potentially creating legal, financial, or reputational liability for the organization.	1. Require manager or legal approval for high-risk external communications. 2. Create an incident process including, how to report a problem, who responds, and how to correct it.

4. Result

Risks documented	5
Controls documented	8